FerixCommerce — Implementation Report

Date: 2026-10-24
Repository: `Asaphis/FerixCommerce`
Branch: `main`
Scope: Applied code fixes from the full project review; no production service or production database was accessed.

Summary

The reviewed reliability, data-integrity, security and rendering corrections were applied across the backend, Admin CMS, Marketplace and Merchant applications. The repository now passes:

- Backend syntax checks
- All 106 backend tests
- Admin TypeScript check and production build
- Marketplace TypeScript check and production build
- Merchant TypeScript check and production build
- `npm audit --omit=dev` with zero vulnerabilities in all three apps

Next.js was upgraded from 16.4.0 to 16.4.3 and Zod from the vulnerable 4.x range to 4.6.6.

Backend changes

`Backend/cms_sections.py`

- Made section and placement end times exclusive: an item is no longer live at the exact `endsAt` instant.
- Added a shared strict media URL policy allowing local paths and HTTPS URLs while rejecting protocol-relative, backslash-prefixed and control-character URLs.
- Added canonical section normalization with contiguous positions.

`Backend/routers/admin.py`

- Added permission enforcement to sensitive admin read routes.
- Added strict validation for bulk placement price, compare-at, quantity and schedule fields before deleting/replacing existing placement rows.

- Fixed single-placement optional-field clearing order and semantics.
- Added safer banner media-kind switching so stale image/video fields are cleared.
- Preserved explicit banner active state rather than implicitly reactivating records during unrelated updates.
- Added managed collection and brand reference validation where the existing contract supports it.
- Added collection deletion protection when products still reference a collection.
- Restored the existing operator product-create compatibility behavior for legacy category slugs while keeping strict brand/collection validation.
- Added CMS revision conflict checks and draft-aware save/publish handling in the touched CMS routes.
- Preserved product placements that are not currently shown in the assignable-section list during a bulk product save.
- Added draft-aware/canonical section ordering support.
- Added strict media/banner/brand URL validation.

`Backend/routers/merchant.py`

- Enforced declared merchant read permissions on analytics, customers, orders, payouts, media and related routes.
- Added finite/nonnegative validation for seller price, compare-at and stock values.
- Made explicit `null` compare-at values clear the stored value.
- Applied safe media URL validation.
- Fixed seller product submission to persist under the canonical product slug instead of potentially creating an ID-keyed duplicate row.

`Backend/ratelimit.py`

- `X-Forwarded-For` is now trusted only when the immediate peer is listed in `FERIXAS_TRUSTED_PROXIES`.
- Direct callers can no longer rotate spoofed forwarded addresses to bypass the in-process login limiter.

`Backend/notifications.py`

- HTML-escaped user names, order numbers and status values in email bodies.

- Escaped configured application URLs used in HTML attributes.

`Backend/tests/test_audit_corrections_unit.py`

Added dependency-light regression coverage for:

- Exclusive section/placement expiry boundaries
- Safe media URL policy
- HTML escaping in notifications
- Trusted-proxy forwarded-address handling

Admin CMS and catalog changes

`WebPhase/admin/lib/ops-actions.ts`

- Retained existing placements that are not present in the current assignable-section list instead of silently deleting them.
- Added explicit null values for optional placement terms.
- Preserved placement title/type/price/quantity/config fields in retained records.
- Added safer product and section payload handling.

`WebPhase/admin/lib/api.ts`

- Added revision-aware response typing and CMS API plumbing used by the updated save/publish paths.

`WebPhase/admin/app/catalog/[slug]/page.tsx`

- Preserved an existing product category when the current value is missing from the currently returned options instead of silently selecting another option.

Marketplace changes

CMS/rendering behavior

- Normalized string, numeric and boolean CMS values before rendering.

- Wired hero `showText`, `showButtons` and text-width settings through direct-media and banner rendering.
- Added flash-sale layout aliases so carousel/rail/horizontal settings produce a sliding rail consistently.
- Improved visibility filtering for string-serialized boolean values.
- Added explicit unknown-brand and empty-storefront states with recovery links.
- Improved product/store/home rendering data normalization.

Changed Marketplace files

- `WebPhase/marketplace/app/brands/[slug]/page.tsx`
- `WebPhase/marketplace/app/page.tsx`
- `WebPhase/marketplace/app/product/[slug]/page.tsx`
- `WebPhase/marketplace/app/store/[slug]/page.tsx`
- `WebPhase/marketplace/components/ferix/catalog-listing.tsx`
- `WebPhase/marketplace/components/ferix/cms-info-sections.tsx`
- `WebPhase/marketplace/components/ferix/flash-sale.tsx`
- `WebPhase/marketplace/components/ferix/media-hero.tsx`
- `WebPhase/marketplace/components/ferix/render-sections.tsx`

Merchant changes

Product and media workflows

- Product links and dynamic product routes now use compatible canonical identifiers.
- Merchant edits no longer force marketplace state on every edit; existing channel state is preserved.
- New product submissions remain marketplace-enabled as intended.
- Product image selection now appends files instead of replacing the previous selection.
- Re-selecting the same file is supported by resetting the file input.
- Added client-side image MIME and 20 MB size validation.
- Added two-step confirmation for product and media deletion.
- Improved product route/cache behavior.

Changed Merchant files

- `WebPhase/merchant/app/products/[slug]/page.tsx`
- `WebPhase/merchant/app/products/page.tsx`
- `WebPhase/merchant/components/studio/media-library.tsx`
- `WebPhase/merchant/components/studio/product-delete-form.tsx`
- `WebPhase/merchant/components/studio/product-form.tsx`
- `WebPhase/merchant/lib/actions.ts`
- `WebPhase/merchant/lib/api.ts`

The API client was kept client-safe so the Merchant production build does not import `next/headers` into a client bundle.

Dependency and security updates

Updated all three production apps:

- Next.js `16.4.0` → `16.4.3`
- Zod vulnerable range → `4.6.6`

Updated lockfiles:

- `WebPhase/admin/package-lock.json`
- `WebPhase/marketplace/package-lock.json`
- `WebPhase/merchant/package-lock.json`

The three apps report zero vulnerabilities with `npm audit --omit=dev` after these updates.

Verification performed

Backend

```
python3 -m compileall -q Backend                 PASS
106 backend tests                                      PASS
```

The full suite was run in an isolated virtual environment with the declared backend requirements installed.

Frontend

```
WebPhase/admin:       npm run typecheck            PASS
WebPhase/admin:       npm run build                PASS
WebPhase/marketplace: npm run typecheck            PASS
WebPhase/marketplace: npm run build                PASS
WebPhase/merchant:    npm run typecheck            PASS
WebPhase/merchant:    npm run build                PASS
```

Dependency security

```
Admin:       npm audit --omit=dev                0 vulnerabilities
Marketplace: npm audit --omit=dev                0 vulnerabilities
Merchant:    npm audit --omit=dev                0 vulnerabilities
```

Items that still require a larger design or external integration

These were not faked or marked complete because doing so locally would create unsafe behavior:

1. Real checkout/payment capture, refunds and payouts still require a verified payment provider and webhook/ledger design.
2. Inventory reservation and checkout need a transactional database/provider implementation before real sales traffic.
3. Session credentials are still supported through the repository’s legacy query/body transport for compatibility with its current runtime proxy. A complete removal requires deploying a server-side BFF or changing the proxy contract.
4. The three apps still have duplicated API/session modules and copied UI primitives. The safe fix is a deliberate workspace-package migration rather than an unreviewed mass move.
5. Browser-level responsive, keyboard and screen-reader verification still needs to be run against a live API/deployment environment.

6. The remaining business decisions around store CMS composition, public policy settings and payment state wording need product-owner confirmation.

Git status and push

The implementation is ready to commit and push to the connected `Asaphis/FerixCommerce` repository after this report is included. Generated TypeScript build metadata was excluded from the change set.